Jr.Pen 9.2.Vulnerability Scanning Tools

Task 1 - Introduction

Vulnerability scanning is an automated process that identifies weaknesses, misconfigurations, and potential security issues across systems, networks, web applications, and devices. It's usually one of the first steps in a penetration test or security assessment.

Learning Objectives

- Understand what vulnerability scanning is and why it is crucial for securing systems and networks
- Learn key concepts, including vulnerabilities, CVEs, CVSS, and common types of scanners
- Gain practical skills using Nmap, OpenVAS, and Nikto to identify and analyse vulnerabilities
- Develop the ability to interpret scan results and understand their security impact
- Learn best practices for performing safe, effective, and ethical vulnerability scans

Task 2 - Important Topics

he goal is to build a clear understanding of core concepts, including vulnerabilities, CVEs, CVSS scores, and common scanner types.

- **Vulnerability:** A system weakness or flaw that enables unauthorized access or security breaches.
- **Common Vulnerabilities and Exposures (CVE):** A standardized ID system used to identify and track known security flaws across security platforms.
- **Common Vulnerability Scoring System (CVSS):** A numerical rating system (0–10) that measures the severity and risk level of a vulnerability.

- **Misconfiguration:** A security weakness caused by improperly configured systems, default settings, or overly broad permissions.
- **Software Vulnerability:** A flaw in application code that causes unintended behavior and requires a developer patch to fix.

Types of Vulnerability Scanners

- **Network Scanner:** A tool that inspects network devices to discover open ports, active services, and potential entry points.
- **Web Application Scanner:** A security tool that checks websites and web applications specifically for flaws at the HTTP/HTTPS layer.
- **Host-Based Scanner:** A tool running directly on a machine to audit internal patches, software versions, and system configurations.

Answer the questions below

> What is the maximum range for a CVSS score?

10

> What is a scanner called that examines devices on a network to identify open ports and running services?

Network Scanner

Task 3 - Nmap

Network Mapper (Nmap) is a widely used network scanning tool that discovers hosts, identifies open ports, and determines which services are running on systems.

Host Discovery: nmap -sn MACHINE_IP (Host discovery determines which devices on a network are active and responding.)

Port Scanning: nmap -sV MACHINE_IP (Port scanning identifies which ports are open and what communication pathways are available.)

Aggressive Scan: nmap -A MACHINE_IP (An aggressive scan performs deeper enumeration, including OS detection, service versions, running scripts, and traceroute.)

Answer the questions below

> What is the FTP port number on the lab machine?

21

> What service is running on port 80 on the lab machine?

WebSockify (nmap -sV MACHINE_IP)

> What is the name of the scripting engine that allows Nmap to run specialised scripts written in Lua to extend its functionality?

Nmap Scripting Engine (The Nmap Scripting Engine allows Nmap to run specialised scripts written in Lua to extend its functionality.)

Task 4 - Nikto Web Scanner

Nikto is a widely used web server vulnerability scanner that identifies insecure configurations, outdated components, and common web-based weaknesses. It performs a comprehensive scan of a target web server and checks it against thousands of known issues, including default files, dangerous HTTP methods, misconfigurations, and potential security exposures. While Nikto is not a stealthy tool, it is extremely effective during early web vulnerability assessments where thoroughness is more important than evasion.

```
ubuntu@tryhackme:~$ nikto -h http://MACHINE_IP:8080

Nikto v2.1.5
---------------------------------------------------------------------------
+ Target IP: 10.82.73.204
+ Target Hostname: ip-MACHINE_IP.eu-west-1.compute.internal
+ Target Port: 8080
+ Start Time: 2025-12-06 16:52:38 (GMT0)
---------------------------------------------------------------------------
+ Server: Apache/2.4.58 (Ubuntu)
```

```
---------------------------------------------------------------------
--------------
+ Server: Apache/2.4.58 (Ubuntu)
+ Cookie PHPSESSID created without the httponly flag
+ The anti-clickjacking X-Frame-Options header is not presen
t.
+ No CGI Directories found (use '-C all' to force check all p
ossible dirs)
+ DEBUG HTTP verb may show server debugging information. See
http://msdn.microsoft.com/en-us/library/e8z01xdh%28VS.80%29.a
spx for details.
+ OSVDB-561: /server-status: This reveals Apache information.
Comment out appropriate line in httpd.conf or restrict access
to allowed hosts.
+ OSVDB-3233: /info.php: PHP is installed, and a test script
which runs phpinfo() was found. This gives a lot of system in
formation.
+ OSVDB-3268: /static/: Directory indexing found.
+ OSVDB-5292: /info.php?file=http://cirt.net/rfiinc.txt?: RFI
from RSnake's list (http://ha.ckers.org/weird/rfi-locations.d
at) or from http://osvdb.org/
+ 6544 items checked: 0 error(s) and 7 item(s) reported on re
mote host
+ End Time:           2025-12-06 16:52:45 (GMT0) (7 seconds)
```

Understanding the Nikto Scan Results

- **Web Server Information Disclosure (Server: Apache/2.4.58)**: Nikto detects the exact server version, which helps attackers look up known vulnerabilities for that version. Ideally, servers should limit the amount of version information to reduce unnecessary exposure.
- **Cookie Missing Security Flags (PHPSESSID created without the HttpOnly flag)**: This means the cookie can be accessed via client-side scripts, increasing the risk of session hijacking. Secure applications normally set both the HttpOnly and Secure flags on cookies used to handle session data.

- **Missing Clickjacking Protection (X-Frame-Options header not present)**: Without this header, the site can be embedded in an iframe, enabling “clickjacking” attacks that trick users into clicking hidden elements.
- **Potentially Dangerous HTTP Method (DEBUG HTTP verb available)**: Some servers respond to uncommon methods, such as DEBUG, which can reveal internal debugging information. This is unnecessary for normal operation and should be disabled to reduce information leakage.
- **Exposed PHP Info Page (/info.php found running phpinfo())**: The `phpinfo()` output reveals extensive system information, modules, configuration values, and environment variables and is commonly removed in production environments. Leaving it accessible introduces high information leakage risks.
- **Directory Indexing Enabled (/static/ directory indexing)**: This allows anyone to browse the contents of a directory without restriction, revealing files that shouldn’t be publicly visible. Directory listing should be disabled unless absolutely required.
- **Remote File Inclusion (RFI) Test Detected (info.php?file=<external_link>)**: Nikto detected a parameter that may be vulnerable to Remote File Inclusion if mishandled. RFI vulnerabilities allow attackers to load code from external servers and execute it on the target system, one of the most severe web risks.

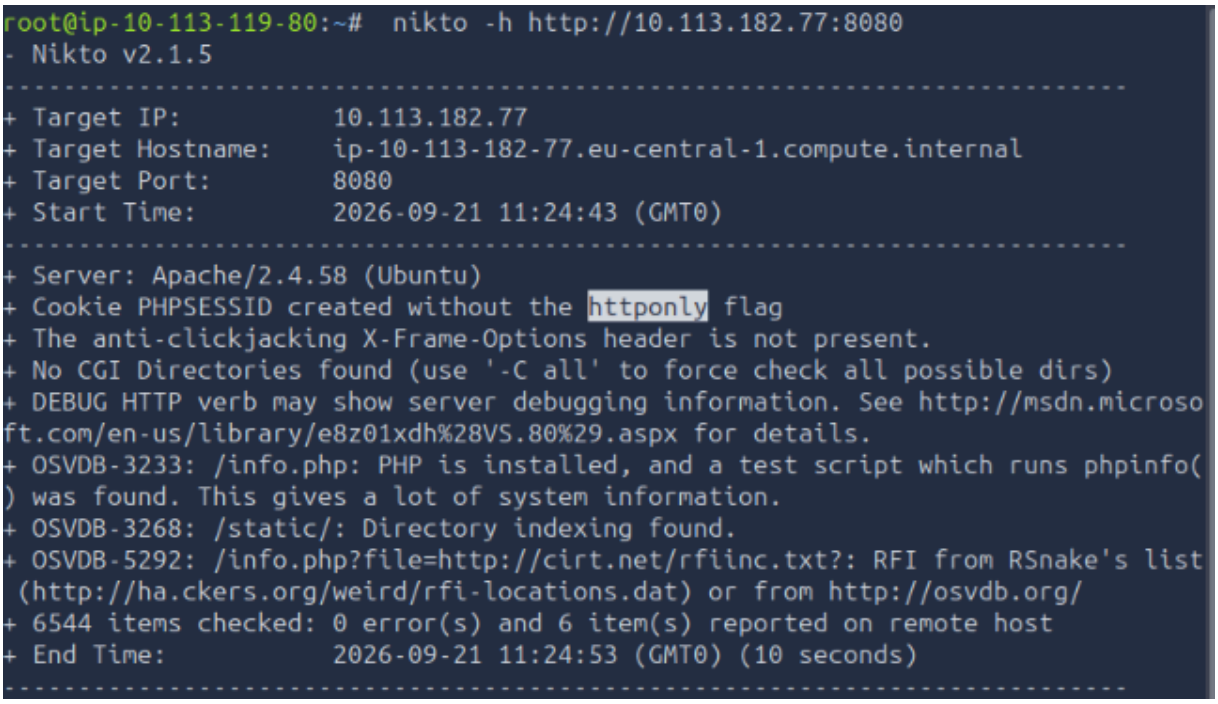
Answer the questions below

> What is the Apache Server version?

2.4.58

> Per the Nikto report, which flag is missing from the cookie in the web app?

HttpOnly



> What is the name of the directory with directory listing enabled?

Static

> What is the parameter vulnerable to RFI?

file

Task 5 - OpenVAS & Greenbone Vulnerability Management

OpenVAS is a powerful vulnerability scanner that assesses both host-level weaknesses and web application security issues. It provides deep, authenticated and unauthenticated scanning, making it ideal for identifying misconfigurations, outdated software, missing patches, and exposed services.

Login with credentials that given by the room, add target, click the `Plus (+)` icon, and enter the target name `SecondTarget` and the IP `MACHINE_IP`. Once the details are filled in, click `Save` to register the target for scanning,

After adding a target, the next step is to create a scan task. Go to `Scans > Tasks`, click the `Plus (+)` icon, and choose `New Task`. Enter the task name `SecondTask` and select the target you added earlier, keep the default scan configuration, and click `Save` to create the task. Once created, click the `Run` button to begin the

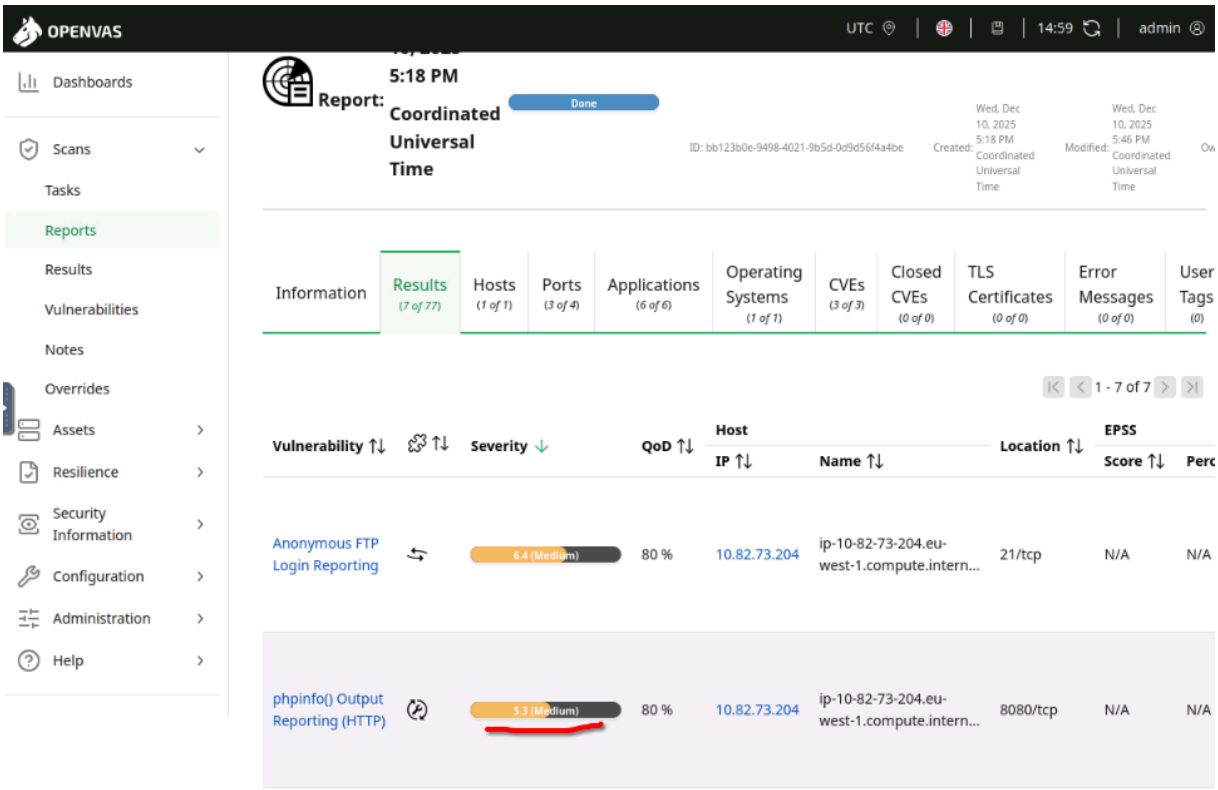
vulnerability scan. OpenVAS will analyse the host and display real-time progress until the scan completes.

To view the results of the `MyTarget` report, go to `Scans > Reports`. Click the report entry for the scan date and time. In the Results tab, the scan findings are listed by severity level, affected ports, and host details. The report highlights issues such as anonymous FTP access, exposed phpinfo pages, missing cookie protections, and weak encryption settings.

Answer the questions below

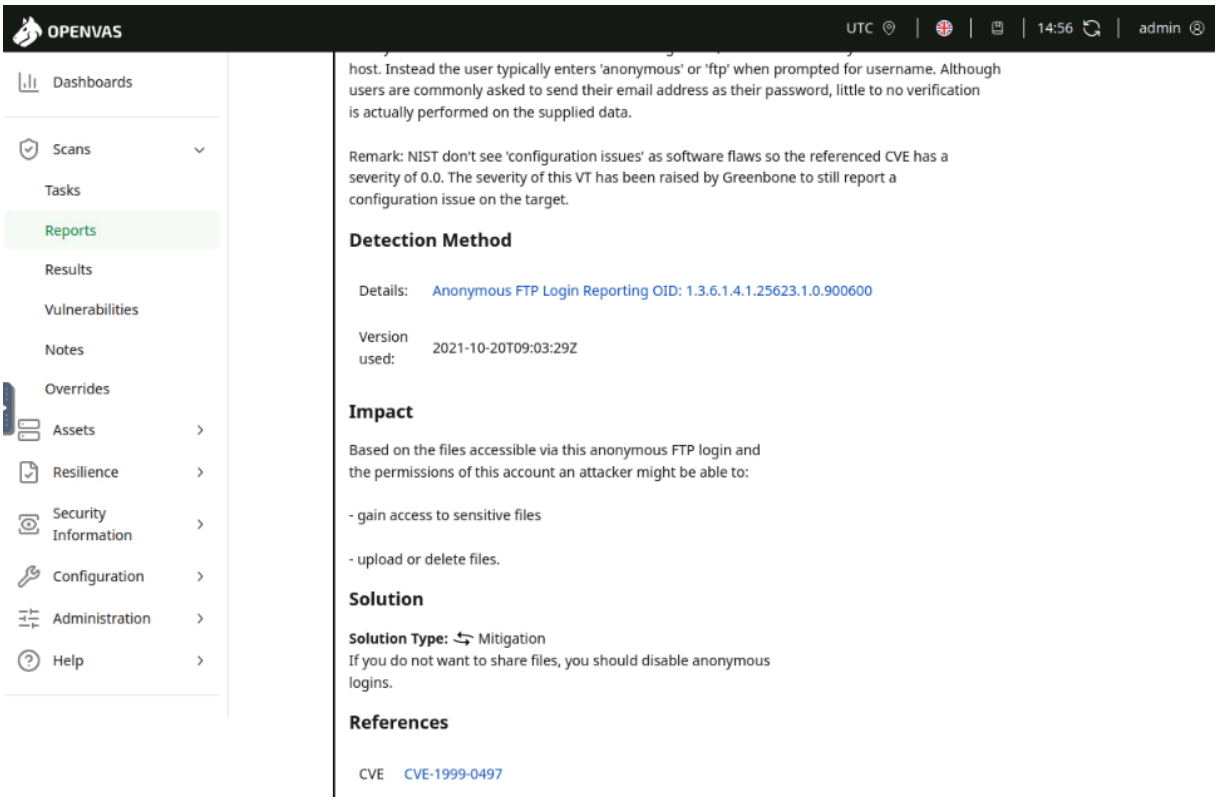
> What is the severity number for the vulnerablility `phpinfo() Output Reporting (HTTP)`?

5.3



> What is the CVE value associated with `Anonymous FTP Login Reporting`?

CVE-1999-0497



> What is the target Operating System?

Ubuntu 24.04 (sudo nmap -O 10.113.182.77)

Task 6 - Best Practices

- **Start Light:** Begin with non-intrusive scans to avoid slowing or disrupting the target system, especially in shared or production environments.
- **Right Tooling:** Match the scanner to the job—use Nmap for network discovery, OpenVAS for deep analysis, and Nikto for web server checks.
- **Verify Results:** Double-check high-severity findings manually because scanners can produce false positives or incomplete information.
- **Stay Updated**: Keep scanning tools and vulnerability feeds up to date so the scanner can identify new CVEs and configuration issues.
- **Use Credentials:** When allowed, run authenticated scans to get more accurate visibility into missing patches and internal weaknesses.

- **Compare Over Time:** Save scan outputs and compare them regularly to track improvements, detect regressions, and monitor newly introduced issues.
- **Scan Smart:** Schedule scans during low-traffic hours since vulnerability scanning can consume noticeable network and system resources.

Task 7 - Conclusion

Vulnerability scanning tools play a critical role in modern cyber security by automatically identifying weaknesses, misconfigurations, and outdated software across systems and networks. These tools help pentesters to detect potential attack vectors before adversaries can exploit them, making them essential for maintaining a strong security posture.

In this room, you gained an understanding of vulnerability scanning and its importance in securing networks and systems, covering:

- What vulnerability scanning is and its importance in securing networks and systems.
- What vulnerabilities are, how they are classified, and why identifying them early is essential for reducing security risks.
- Using Nmap, OpenVAS, and Nikto to identify, analyse, and interpret vulnerabilities effectively.
- What the best practices are for performing safe and ethical scans.